HCL PROJECT-BASED LEARNING | CYBERSECURITY TRACK

Security Incident Detection & Analysis Report

Formal Security Incident Investigation, Root-Cause Analysis, & Remediation Playbook

Course / Module	Security Incident Detection and Analysis (Project 1)
Project Scope	DNS Tunneling, Covert C2 Communication & Data Exfiltration
Author / Candidate	Harsh Juneja
Live Deployment & Repo	Web App: incident-detection-dns-tunneling.streamlit.app GitHub: github.com/Harsh18062005/incident-detection-dns-tunneling

1. Executive Summary

During continuous security monitoring of the enterprise network perimeter, a high-severity incident involving DNS Tunneling and covert Command-and-Control (C2) communication was identified. Adversaries weaponized the Standard Domain Name System protocol (UDP/TCP Port 53) to exfiltrate serialized, encrypted corporate data while circumventing traditional signature-based edge firewalls. Through real-time packet inspection and heuristic telemetry correlation, the Security Operations Center (SOC) detected, investigated, contained, and remediated the threat, preventing full data compromise.

Section a. Incident Summary

In accordance with Section a of the HCL Incident Analysis Guidelines, the core attributes of the detected security event are summarized below:

Incident Type	DNS Tunneling / Data Exfiltration over Covert C2 Channel (MITRE ATT&CK T1071.004, T1041)
Date & Time of Incident	2026-10-31 00:20:00 UTC (Real-Time Monitoring Session)
Incident Severity Level	**CRITICAL (Risk Score 7/7 - Multi-Stage Encrypted Payload Exfiltration)**
Affected Assets	Workstation Subnet: 192.168.1.7, 192.168.1.10, 192.168.1.3 (Host Endpoint Devices)
Attack Vector	Abuse of Recursive External DNS Resolvers using encoded high-entropy subdomains

Incident Status	**CONTAINED & REMEDIATED - Malicious Domains Sinkholed, Threat Signatures Updated**

Section b. Detection and Analysis

The SOC environment deployed a defense-in-depth detection architecture utilizing live packet sniffers, mathematical feature extractors, and heuristic correlation engines to identify anomalous DNS behavior.

1. Tools & Platforms Utilized

- Network Packet Ingestion: Scapy (Promiscuous Mode Socket Sniffing) & Wireshark / tcpdump PCAP Ingestion.
- Security Dashboard & Visualization: Streamlit Enterprise SOC Platform (Incident Trend Analysis & Risk Metrics).
- Analytics & Heuristic Engine: Python 3.11 with NumPy and Pandas telemetry pipelines.
- Threat Intelligence & Framework: MITRE ATT&CK Framework (T1071.004, T1041).
- Continuous Integration / Testing: GitHub Actions CI Matrix (11 Automated Unit Tests across Python 3.10/3.11).

2. Technical Investigation Findings & Heuristic Feature Extraction

DNS queries were extracted and evaluated across five primary heuristic telemetry dimensions to calculate an explainable Risk Score (0–7):

Heuristic Metric	Threshold Trigger	Weight	Security Rationale & Observation
Domain Length	> 50 characters	**+2**	Observed queries exceeded 65 chars (e.g. 68-char encoded payload).
Subdomain Depth	≥ 2 subdomains	**+1**	Multi-stage payload encapsulation (.exfil-c2.net, .data-tunnel.org).
Shannon Entropy	> 3.5 bits/char	**+2**	Observed entropy peaked at 4.23 bits/char, confirming Base64 encryption.
Query Frequency	≥ 5 queries	**+1**	Burst beaconing detected from source IP 192.168.1.7 within short intervals.
Query Record Type	TXT Query	**+1**	Payload exfiltration leveraged TXT records to maximize response buffer size.

3. Incident Timeline Reconstruction

SOC analysts reconstructed the step-by-step chronology of the attack based on chronological packet telemetry:

Timestamp	Phase / Stage	Observed Telemetry & Activity
00:20:02 UTC	Reconnaissance / Normal Traffic	Baseline queries generated (google.com, github.com) by normal enterprise users.
00:20:07 UTC	Initial C2 Beaconing	First anomalous TXT query from 192.168.1.7: beacon-fgi4tfmz1o4k9vc.example.com (Risk: 5/7).
00:20:12 UTC	Bulk Data Exfiltration	Burst of 18 high-entropy TXT queries carrying encoded binary data chunks (Entropy: 4.19, Risk: 7/7).
00:20:15 UTC	Automated SOC Trigger	Threshold rule triggered: 20 critical alerts flagged; automated containment initiated.

Section c. Mitigation and Recovery

Upon positive confirmation of active DNS exfiltration, the SOC executed incident containment and recovery workflows in alignment with standard incident response playbooks:

1. Host Isolation & Quarantine: Source endpoints 192.168.1.7, 192.168.1.10, and 192.168.1.3 were immediately segmented from the internal local area network (VLAN isolation) to prevent lateral movement.

2. Threat Domain Sinkholing: Adversary command-and-control domains (*.example.com, *.exfil-c2.net, *.data-tunnel.org) were null-routed / sinkholed at the perimeter internal DNS forwarders.

3. Perimeter Firewall Egress Filtering: Configured egress firewall rules to drop all direct outbound UDP/TCP Port 53 traffic from internal client subnets. Only authorized enterprise DNS servers are permitted outbound resolution.

4. Endpoint Forensic Analysis & Cleanup: Forensic scans of isolated hosts identified unauthorized PowerShell and Python-based exfiltration scripts. Malicious processes were terminated, artifacts quarantined, and active directory user sessions revoked.

5. Post-Remediation Telemetry Verification: Live monitoring confirmed zero subsequent anomalous TXT queries or high-entropy requests. Endpoint integrity verified prior to network reconnection.

Section d. Future Recommendations

To strengthen the organizational security posture and enhance long-term threat resilience, the following preventive controls and monitoring improvements are recommended:

A. Preventive Technical Controls

- Deploy DNS Response Policy Zones (RPZ) and DNS Threat Intelligence feeds to automatically block newly registered domains (NRDs).
- Implement Zero Trust Network Access (ZTNA) with micro-segmentation between user workstations and internal data stores.
- Enforce centralized DNS over HTTPS/TLS (DoH/DoT) inspection at the enterprise proxy level.

B. SOC Monitoring & Detection Optimization

- Integrate automated real-time Shannon entropy calculation into the centralized SIEM ingestion pipeline.
- Establish automated playbooks (SOAR) to auto-isolate endpoints triggering consecutive High or Critical DNS tunneling scores.
- Continuously tune correlation rules to reduce false positives for legitimate developer tool subdomains (e.g., CDN, AWS, GitHub).

C. Policy & Governance Enhancements

- Update Acceptable Use Policies (AUP) explicitly forbidding unauthorized local DNS resolution agents and third-party VPN tunnelers.
- Mandate quarterly red-team / purple-team DNS tunneling emulation exercises to test SOC detection readiness.

D. Security Awareness Training

- Conduct targeted anti-phishing and social engineering workshops for high-risk department personnel to prevent initial endpoint compromise.

Section e. Conclusion & Audit Verification

This project successfully demonstrated the full lifecycle of Security Incident Detection and Analysis—from live telemetry ingestion and explainable heuristic evaluation, to incident triage, timeline reconstruction, and mitigation playbook execution. All project components, automated test suites, and live dashboards are verified and accessible via the links below:

Live SOC Web Dashboard	https://incident-detection-dns-tunneling.streamlit.app/
GitHub Repository (Code & CI)	https://github.com/Harsh18062005/incident-detection-dns-tunneling
Automated Test Suite Status	11 Unit Tests Passing (0.025s execution) across Python 3.10 & 3.11
CSV Telemetry & Alerts	Available via one-click download in dashboard or project data/ folder